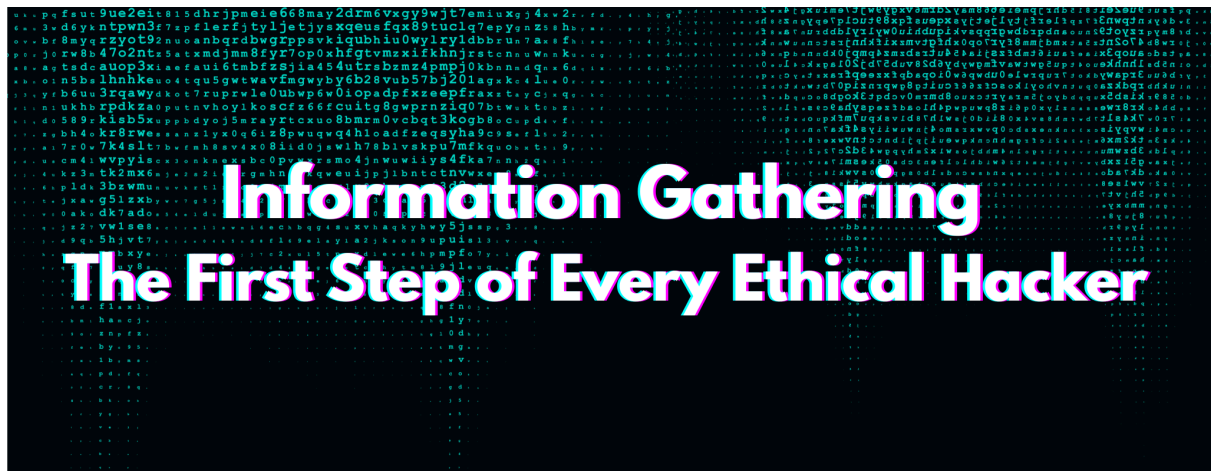




Information Gathering – The First Step of Every Ethical Hacker

What is Information Gathering?

Information Gathering (also called *Reconnaissance* or *Footprinting*) is the **foundation of penetration testing**.

It involves **collecting, analyzing, and correlating information** about a target before launching any attacks.

The goal is to create a detailed **attack surface map** that helps identify:

- What assets exist
- How they connect
- What technologies and people are involved
- Where the vulnerabilities may lie

In short, it's the **digital blueprint** of a target organization — built without triggering alarms.

Objectives of the Reconnaissance Phase

Ethical hackers gather information to:

- Identify **IP ranges, domains, subdomains, and DNS records**

- Discover **open ports, services, and running technologies**
- Collect **employee names, email formats, and organizational hierarchy**
- Detect **leaked credentials**, public vulnerabilities, and **third-party exposures**
- Understand **target architecture** before exploitation or detection

| "A strong recon defines how accurate your exploitation will be."

Types of Information Gathering

1 Passive Information Gathering (OSINT)

Passive reconnaissance is conducted **without directly interacting** with target systems.

It relies on **publicly available information** and leaves **no digital footprint** on the target's network.

This is the most **legal, stealthy, and widely used** method in professional pentesting.

Common OSINT Data Sources

-  **Search Engines (Google Dorking)** → `site:target.com filetype:pdf`
-  **Social Media** → LinkedIn, Twitter, GitHub for employee leaks or credentials
-  **Public Databases** → Whois, DNSdumpster, Netcraft, Archive.org
-  **Job Boards** → Reveal internal tech stacks ("hiring Linux admin for Nginx server")
-  **Shodan / Censys** → Identify public servers, IoT, and open ports
-  **Google Maps** → Used for physical security assessment (OSINT extension)

Goal: To silently build a **comprehensive picture of the target's digital footprint**.

2 Active Information Gathering

Active reconnaissance means **directly interacting** with the target systems — typically allowed only under **written authorization**.

It reveals technical details such as **open ports, active hosts, network structure, and running services**.

Examples & Commands:

- **Ping Sweep:**

`ping -c 1 target.com` → Checks if a host is live

- **Traceroute:**

`traceroute target.com` → Maps the path to the target

- **Port Scanning (Nmap):**

`nmap -sS -sV -p- target.com` → Scans all ports & detects service versions

- **Banner Grabbing (Netcat):**

`nc target.com 80` → Displays service details and version

- **DNS Enumeration:**

`dnsrecon -d target.com -t brt` → Discovers subdomains and DNS records

Goal: To understand *what's running, where, and how it can be exploited safely*.

Top Tools Used in Information Gathering

Tool	Purpose	Example
 Netcraft	Reveals website hosting, SSL, and tech stack	Search <code>site:target.com</code>
 Whois	Finds domain registration, contact, and expiry info	<code>whois target.com</code>
 DNSRecon / Nslookup	Maps DNS records and subdomains	<code>nslookup -type=ANY target.com</code>
 theHarvester	Gathers emails, subdomains, and hosts	<code>theHarvester -d target.com -b google</code>
 Shodan	Scans for internet-connected devices	Search <code>org:"Target Company"</code>
 Censys / FOFA	Finds SSL certificates, IPs, and exposed assets	Web-based OSINT search

Tool	Purpose	Example
 Maltego	Creates graphical OSINT relationship maps	Visual data correlation
 Recon-ng	Framework that automates recon data collection	Modular automation tool

Example Workflow – Building the Attack Surface

Step 1: Run **Whois** to identify domain owner & contact info

Step 2: Use **DNSRecon** to find subdomains and records

Step 3: Crawl with **theHarvester** to find emails & employees

Step 4: Use **Shodan / Censys** to locate open ports & public servers

Step 5: Correlate data into an **Attack Surface Map**

 **Output:**

A complete list of:

- Domains & Subdomains
- IP ranges & Technologies
- Open Ports & Services
- Exposed Data & Credentials

Understanding Port Scanning

Port scanning is a vital part of active reconnaissance.

It helps identify **open, filtered, or closed ports** and the services behind them.

Scan Type	Description
TCP Connect (-sT)	Full 3-way handshake; logged by firewalls
SYN Scan (-sS)	Half-open; stealthier and faster
UDP Scan (-sU)	Detects UDP services (DNS, SNMP, NTP)
Network Sweep (-sn)	Identifies live hosts in a subnet

Example:

```
nmap -A --top-ports=20 target_network
```

This command performs:

- OS detection
- Script scanning
- Service versioning
- Traceroute mapping

Living Off the Land (LOLBAS)

Ethical hackers often use **built-in system tools** to gather information — this is called *Living Off the Land*.

It minimizes detection and simulates how real attackers operate.

Examples:

- `nslookup` → DNS query
- `netstat` → Open connections & ports
- PowerShell scripts → System recon
- Windows CMD utilities → `ipconfig /all` , `systeminfo`

Ethical & Legal Boundaries

-  **Passive Recon:** Legal if information is **publicly available**
-  **Active Recon:** Requires **written authorization** or **engagement scope**
-  **Unauthorized probing** = illegal under cyber laws (like IT Act Section 66 in India)
-  Always follow **Responsible Disclosure** principles

Pro Tips for Professionals

- Cross-check multiple OSINT tools — never rely on one data source
- Store and timestamp all findings (Excel, recon logs, or markdown reports)
- Automate repetitive scanning with **Recon-ng**, **SpiderFoot**, or custom scripts

- Always verify outputs before launching any exploit or payload
 - Remember: *"Reconnaissance is quiet success — exploitation is loud failure."*
-

Why It Matters

- 80% of a successful penetration test depends on **the quality of reconnaissance**.
 - Recon reduces false positives and minimizes attack noise.
 - Both **Red Teams (attackers)** and **Blue Teams (defenders)** use recon to:
 - Find weaknesses
 - Understand exposure
 - Strengthen defenses
-

Key Takeaways

- ✓ Recon = *Knowledge Gathering*, not Exploitation
 - ✓ Passive → Active → Enumeration → Exploitation
 - ✓ The more you know, the less you guess
 - ✓ Ethical hackers win through preparation, not luck
-

 ***By Omkar Sawant | Cybersecurity Student & Ethical Hacker***
